

Access Control Policy

Organization: Techno Optics LLC (operating Taxottic) **Document version:** 1.0 **Effective date:** 2026-05-04
Owner: Information Security Lead, Techno Optics LLC **Review cadence:** Quarterly access review; full Policy reviewed annually

1. Purpose

This Access Control Policy ("Policy") defines how Techno Optics LLC grants, restricts, monitors, and revokes access to systems and data that support the Taxottic application. It implements the access-management commitments in our Information Security Policy and gives operations personnel a clear, auditable rule for every type of identity that interacts with the production environment.

The Policy applies to consumer end-users, firm and business customers, internal personnel, and machine identities (service accounts, API keys, tokens) used by the application or its third-party processors.

2. Scope

This Policy covers:

- The Taxottic web application (`taxottic.com`) and the administrative console (`hq.taxottic.com`).
- The Postgres database operated by Supabase, including row-level security policies and the service-role key.
- Object storage (Supabase Storage), edge functions, and webhook endpoints.
- Third-party administrative consoles for Vercel, Supabase, Plaid, Stripe, and Anthropic.
- All credentials, API keys, OAuth client secrets, and access tokens used to integrate the above.
- Personnel devices that hold any of the above credentials.

3. Guiding Principles

1. **Least privilege.** Every identity is granted the minimum permissions needed for its role, and no more.
2. **Strong authentication.** Passwords alone are not used. End-users authenticate via phishing-resistant credentials (passkeys / WebAuthn) or federated SSO (Google, Microsoft) that requires multi-factor authentication on the identity provider. Internal personnel use SSO-backed accounts with hardware-backed MFA.

3. **Default deny.** Database tables are default-deny via row-level security; access is granted only by an explicit policy keyed to the authenticated user's identity.
4. **Separation of duties.** Application code uses scoped user sessions; only narrowly scoped backend routes use the service-role key, and never on behalf of a request that has not been authenticated.
5. **Auditability.** Access events (sign-in, passkey enrolment, MFA challenge, admin action) are logged and retained per the Data Retention and Disposal Policy.

4. Identity Classes

Class	Authentication	MFA	Authorisation model
Consumer end-user	Passkey (WebAuthn), Google SSO, Microsoft SSO, or magic link to verified email	Phishing-resistant (passkey) or IdP-enforced MFA	Self-scoped: row-level security restricts every query to rows owned by the authenticated user
Firm / business member	Same as consumer end-user, plus firm membership	Same as consumer end-user	Firm-scoped: RLS plus a firm-membership helper restricts access to the firm's clients and engagements
Firm administrator	Same as firm member	Same as firm member	Firm-admin role; can manage firm members and engagements but not other firms
Internal personnel	Personal SSO account (Google or Microsoft) with hardware MFA at the IdP	Required at the IdP	Read-only access to production by default; write access to production granted ad-hoc with logged justification
Application backend (server-side)	Supabase service-role JWT loaded from environment	N/A — machine identity, key never exposed to the client	Restricted to backend routes; bypasses RLS only when the route has already authenticated the human caller
Plaid integration	Per-Item access token, encrypted at rest with AES-256-GCM, decrypted just-in-time inside backend routes	N/A — machine identity	Access token can only be used to call Plaid for the specific user it belongs to
Webhook callers (Plaid)	JWT signed by Plaid and verified against Plaid's published JWKS	N/A	Webhook handler accepts only events that pass JWT signature verification

5. Provisioning and De-provisioning

- **Consumer end-users** self-provision via the public sign-up flow. They provision their own MFA factor (a passkey, or the MFA configured on their Google / Microsoft SSO).
- **Firm members** are invited by a firm administrator. The invitation is keyed to the invitee's verified email and expires if not accepted.
- **Internal personnel** are added by the Information Security Lead, who issues a SSO-backed account, enrolls hardware MFA, and grants the minimum production access required for the role. Onboarding is logged in the operations runbook with the date and the access scope granted.
- **De-provisioning** is performed within **24 hours** of a personnel departure or role change. Steps: (1) revoke SSO account at the IdP; (2) rotate any service-role keys the person held; (3) remove the person from third-party admin consoles (Vercel, Supabase, Plaid, Stripe, Anthropic); (4) record the event in the runbook.

6. Authorisation: Row-Level Security

Every multi-tenant table in the production database has Row Level Security enabled and is governed by explicit policies that key on `auth.uid()` or a firm-membership helper. Examples:

- `bank_connections`, `bank_accounts`, `account_transactions` — RLS limits each row to its owning user; firm-scoped roles see rows for the engagement only after a firm-membership check.
- `bank_connection_secrets` — RLS enabled with **no policies**, restricting access to the service-role key only. The application backend decrypts tokens just-in-time inside a narrow set of routes.
- `firm_*` tables — RLS keys on a firm-membership helper and an admin-role check.

New migrations are reviewed for RLS coverage; merging a migration that adds a multi-tenant table without RLS is a defect.

7. Authorisation: Application Code

- All authenticated API and page routes call the `requireUser()` helper, which validates the Supabase session, hydrates the user, and short-circuits unauthenticated requests to the sign-in page.
- Admin-only routes call `requireUserWithAdmin()`, which additionally verifies the user holds the admin role.
- The service-role key is only loaded inside server-side modules. It is never sent to the browser, never logged, and never embedded in a URL.
- Webhook routes verify the JWT signature on every request before doing any work.

8. Multi-Factor Authentication

- **End-users** authenticate via a phishing-resistant credential. Passkeys (WebAuthn / FIDO2) are preferred and use platform authenticators (Touch ID, Face ID, Windows Hello, Android biometrics). Federated SSO is accepted on the basis that Google and Microsoft enforce MFA at the identity-provider level for accounts that opt in.

- **Internal personnel** must enable hardware-backed MFA (FIDO2 security key or platform authenticator) on their Google or Microsoft account and may not disable it while they hold production access.
- Magic-link sign-in via email is offered as a fallback; the email account itself is the authentication factor and is expected to have its own MFA. We treat magic-link sessions as equivalent in trust to a verified-email second factor and do not allow magic-link-only sessions to perform high-risk operations (changes to subscription, exports of full historical data) without re-authentication via passkey or SSO.

9. Token, Key, and Certificate Management

- **TLS certificates** for `taxottic.com`, `hq.taxottic.com`, and Vercel-managed subdomains are issued and renewed automatically by Let's Encrypt via Vercel.
- **Plaid access tokens** are encrypted with AES-256-GCM at rest using a key held outside the database. The key is loaded into application memory at startup and is never written to disk on application servers. See migration `20260504000002_bank_token_encryption.sql` and `lib/crypto/bankTokens.ts`.
- **Plaid webhook JWTs** are verified against Plaid's published JWKs on every request; signing keys are cached and rotated on Plaid's schedule. See `lib/plaid/webhookVerify.ts`.
- **Supabase service-role JWT** is held in Vercel's encrypted environment variables and is rotated when a personnel change requires it.
- **OAuth client secrets** (Google, Microsoft, Plaid) are held in Vercel's encrypted environment variables and are rotated annually or sooner if compromise is suspected.
- **Personal API keys** issued to users (none today; reserved for future API surface) will be hashed at rest and revocable from the user's settings page.

10. Network Boundary

- Application code runs as Vercel serverless functions at the edge; there is no long-lived application server that personnel can SSH into.
- Postgres is exposed only via the Supabase API; direct database connections are restricted to the Supabase pooler and authenticated by the service-role key.
- Administrative consoles for Vercel, Supabase, Plaid, Stripe, and Anthropic require SSO-backed accounts with MFA at the identity provider.
- We do not run a corporate VPN; all access to production goes through SSO + MFA at the relevant vendor's portal.

11. Logging and Monitoring

The following access events are logged and retained per the Data Retention and Disposal Policy:

- Sign-in (success and failure).
- Passkey enrolment, deletion, and challenge response.
- MFA challenge response at the IdP (visible to us only as session metadata).

- Admin actions (firm administration, account deletion, refund issued).
- Service-role queries are logged at the Supabase tier; we review the log on demand during incident triage.

12. Access Reviews

- **Quarterly** the Information Security Lead reviews every internal personnel account and every third-party admin-console membership, confirming that each person still requires the access they hold and that MFA is enabled.
- **On role change** the access scope is re-baselined within 7 days.
- **On personnel departure** access is revoked within 24 hours (see §5).

Findings from each review are recorded in the operations runbook.

13. Exceptions

Any exception to this Policy must be approved in writing by the Information Security Lead and recorded in the operations runbook with a justification, scope, and expiry date. Exceptions are reviewed at the next quarterly compliance check.

14. Contact

Access requests, account de-provisioning, and audit inquiries: privacy@taxottic.com. Vulnerability reports: security@taxottic.com.

Information Security Lead, Techno Optics LLC.